



從漏洞開始的一切

資安藍隊地圖與 AI 無法取代的人

Sep 21, 2026 at 臺大資工 資訊安全原理與實務



線上提問 Slido

- > 歡迎任何問題
- > Code : **3736369**
- > <https://sli.do/3736369>





黃俊嘉 Ice1187

- > CyCraft 奧義智慧科技 資安研究員
- > 台大資工 NSLab
- > 研究領域
 - > AI Agent Security, Fuzzing, Malware Analysis
- > 研究發表
 - > ACM CCS (poster), SINCON, SEECON, CyberSec



究竟什麼是漏洞？

> 外送點餐單上哪裡有問題？

外送	
免洗餐具： 是	
顧客備註：	
1 x 薯餅蛋吐司 Toast	50TWD
1 x 火腿三明治套餐 Ham Sandwich Set	100TWD
飲料選擇 DRINK CHOICES	
1 x 紅茶 Black Tea	--
選擇 CHOICES	
1 x 冰 Ice	--
顧客備註： 「不要加醬」	
2 x 荷包蛋 Over Egg	30TWD
荷包蛋選擇 CHOICE OVER EGG	
2x 半熟 Over Medium Egg	--
1 x 熱狗 Hot Dog	30TWD
口味選擇 FLAVOR CHOICE	
1x 原味 Original	--
小計	160TWD
已付金額	160TWD
感謝您向 Restaurant 訂購美食	

外送點餐單上的注入攻擊

- > 顧客備註偷加了一份薯餅蛋吐司
- > 未能區分「系統指令」與「外部資料」
- > 程式中也會出現同樣的問題

外送	
免洗餐具： 是	
顧客備註：	
1 x 薯餅蛋吐司 Toast	50TWD
1 x 火腿三明治套餐 100TWD	
Ham Sandwich Set	
飲料選擇 DRINK CHOICES	
1 x 紅茶 Black Tea	--
選擇 CHOICES	
1 x 冰 Ice	--
顧客備註：	
「不加醬」	
2 x 荷包蛋 Over Egg 30TWD	
荷包蛋選擇 CHOICE OVER EGG	
2x 半熟 Over Medium Egg	--
1 x 熱狗 Hot Dog 30TWD	
口味選擇 FLAVOR CHOICE	
1x 原味 Original	--
小計 160TWD	
已付金額 160TWD	
感謝您向 Restaurant 訂購美食	



如果你是負責處理這個問題的外送平台資安團隊，
你可以做些什麼？

主動識別威脅



設立保護機制

- > 平台每天幾十萬筆訂單
- > 在 App 裡拒絕奇怪的備註內容：
 - > [數量] x [品項名] [價格]TWD 格式的備註
 - > 長度異常地長的備註

偵測異常行為並提出告警

- > 自動標註可疑訂單
 - > 出現價格格式 (像 “50TWD”)
 - > 出現菜單上的品項名稱
- > 偵測到可疑訂單之後，通知店家
 - > 在備註欄顯示警示標記

外送	
免洗餐具： 是	
顧客備註： 請核實備註內容	
1 x 薯餅蛋吐司 Toast	50TWD
1 x 火腿三明治套餐 Ham Sandwich Set	100TWD
飲料選擇 DRINK CHOICES	
1 x 紅茶 Black Tea	--
選擇 CHOICES	
1 x 冰 Ice	--
顧客備註： 「不要加醬」	
2 x 荷包蛋 Over Egg	30TWD
荷包蛋選擇 CHOICE OVER EGG	
2x 半熟 Over Medium Egg	--
1 x 熱狗 Hot Dog	30TWD
口味選擇 FLAVOR CHOICE	
1x 原味 Original	--
小計	160TWD
已付金額	160TWD
感謝您向 Uber Restaurant 訂購美食	

建立受害店家的應變與復原機制

- > 如果有店家已經按照假的備註出餐了，我們需要一套應變流程
 - > 店家回報問題
 - > 平台啟動調查
- > 損害復原的機制
 - > 確認是惡意行為後退款給店家
 - > 停用該顧客帳號

研究攻擊方式與問題的根源

- > 什麼類型的店家容易受到攻擊？為什麼？
- > 店家容易誤讀外送單的原因為何？
- > 什麼樣的 UI 設計才降低誤讀的機率？
- > 備註欄還能怎麼被濫用？
 - > 改成上傳圖片
 - > 用特殊的文字編碼來繞過偵測機制
- > 有沒有比正則表達式或關鍵字配對更好的偵測方式？
 - > 分析備註的語意

從根本**改善**問題

> 這個漏洞最根本的問題

- > 外送單把「平台產生的指示」與「使用者輸入的資料」混在一起

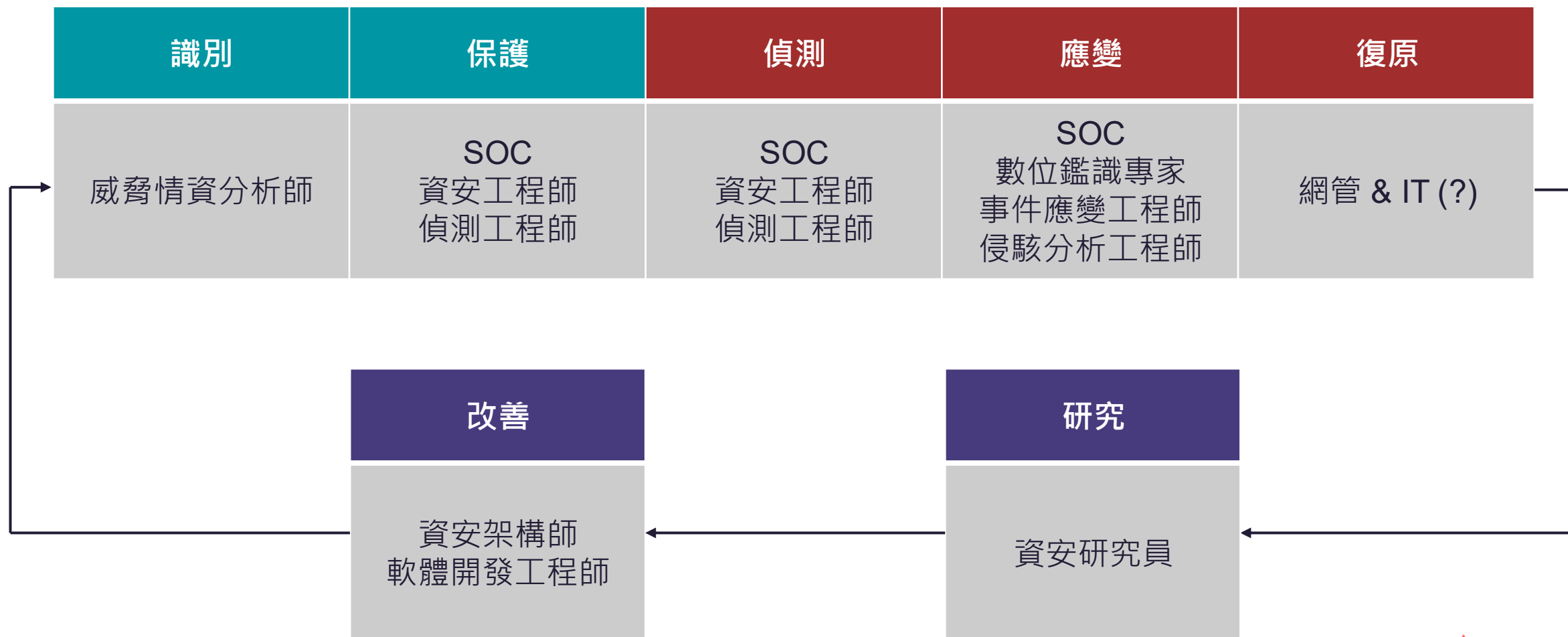
> 將研究累積的成果落地，從架構層面去解決問題

- > 改外送單的呈現方式，讓備註欄跟餐點項目在視覺上完全區隔開

- > 不同顏色

- > 不印在同一張單上

藍隊資安的循環



資安藍隊的核心知識、技能與工具



威脅情資分析師

威脅情資分析師



駭客組織

- > 將(非)公開資安報告的駭客組織入侵特徵、慣用手法、惡意程式行為等整理成清單，交給偵測工程師寫成規則

偵測工程師

> 把「Word 生出 PowerShell」寫成偵測規則

威脅情資分析師

偵測工程師



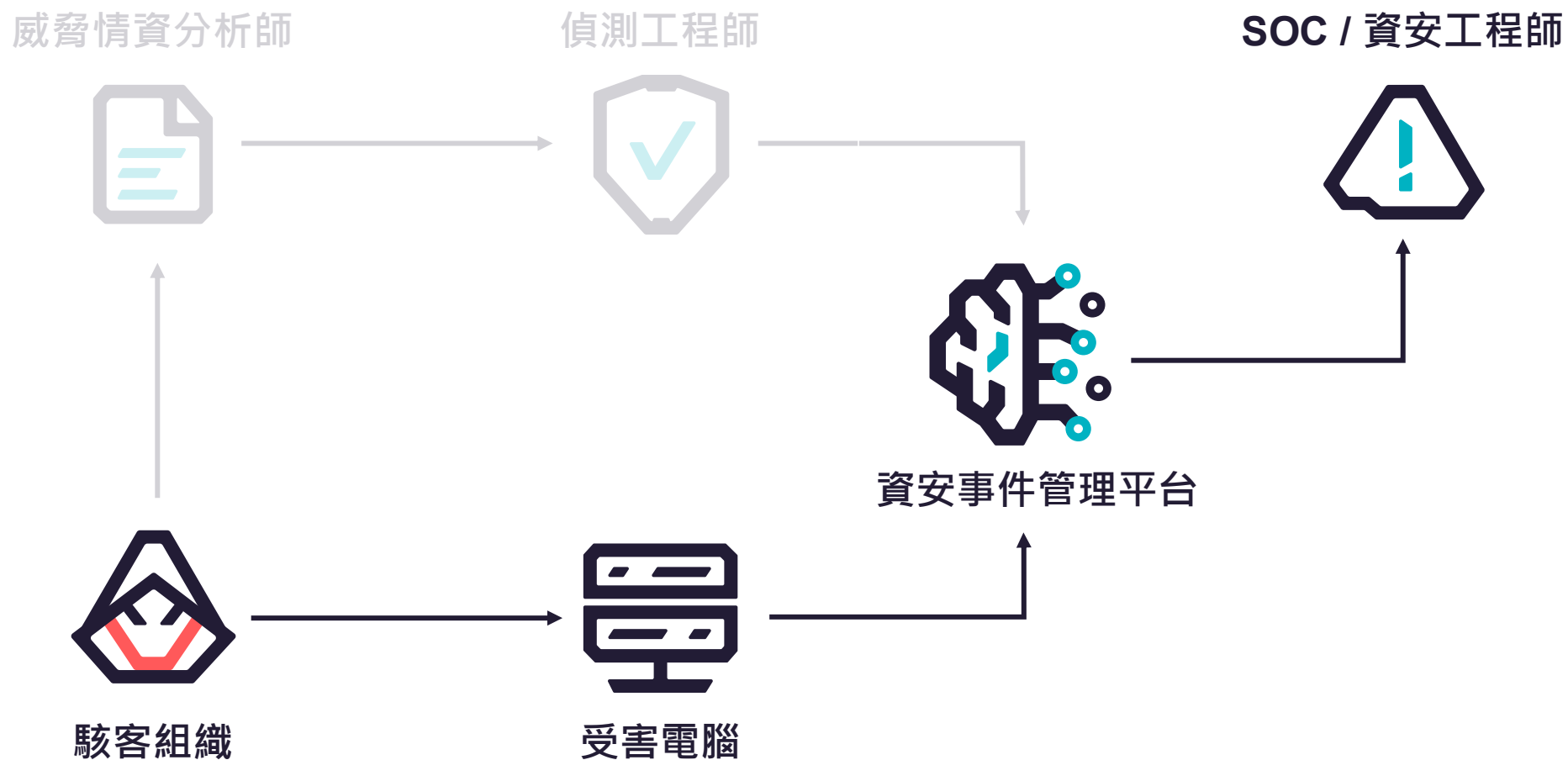
資安事件管理平台



駭客組織

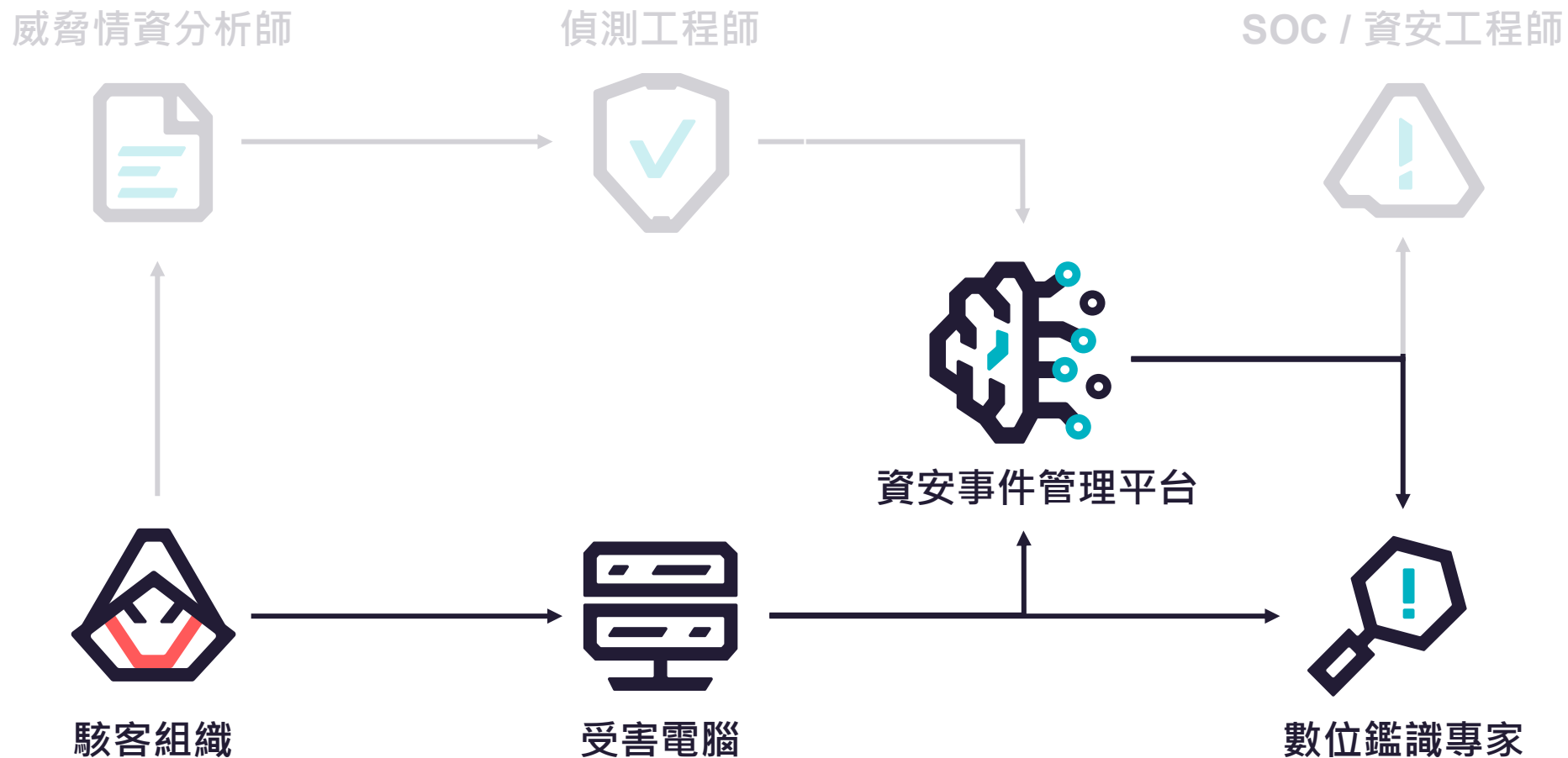
SOC / 資安工程師

> 從數萬筆告警裡查出「某帳號從國外登入」
是出差還是被盜，以及入侵來源與影響範圍



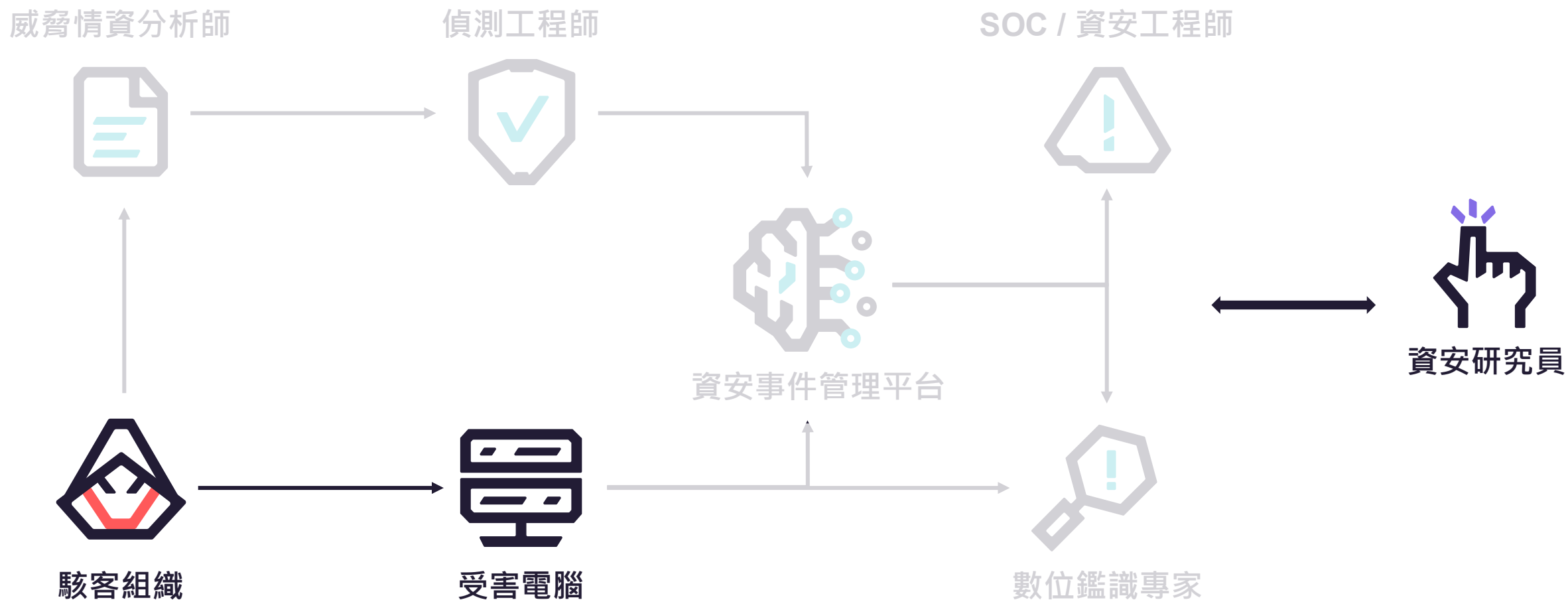
數位鑑識專家

- > 分析被入侵電腦的記憶體與硬碟資料，並排出事件時間軸：起因於釣魚附件、惡意程式做了哪些事、把哪些資料傳出去



資安研究員

- > 對受害產品、駭客行為、攻擊手法、防禦漏洞等面向進行研究，提出洞見或開發新的技術，並投稿分享



資安工作的一些特性

不同職位的工具和技能
差異甚大。

1. 許多基礎知識與技術是通用的

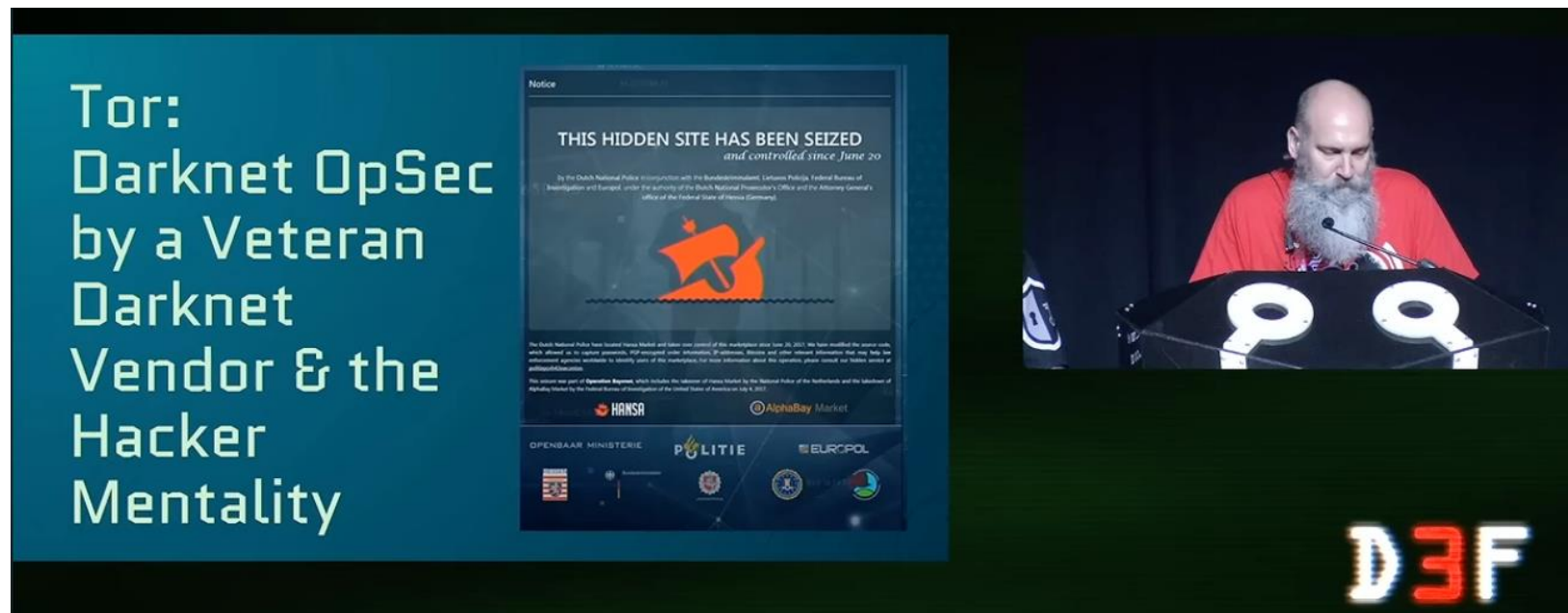
- > 程式與網頁漏洞的成因 $\longleftrightarrow$ 事件追蹤與分析
- > 惡意程式攻擊手法 $\longleftrightarrow$ 數位鑑識
- > 逆向工程 / 網路 / 密碼學 / 身份認證的基礎知識

2. 資安工作十分注重實作能力

- > 不能只停留在「理解原理」的知識層級
- > 知識原理 $\rightarrow$ 工具操作 $\rightarrow$ 技能演練 $\rightarrow$ 實際運用

技術：情資收集 & 暗網臥底

- > 駭客集團追蹤
- > 情資收集與分析
- > 暗網
- > 群組臥底
- > 自動化



Darknet Opsec By a Veteran Darknet Vendor

技術：逆向工程

- > 程式運作原理
- > 作業系統運作原理
- > 檔案格式結構
- > 惡意程式開發
- > 工具
 - > IDA / Ghidra
 - > GDB (GNU Debugger)

Hex-Rays C

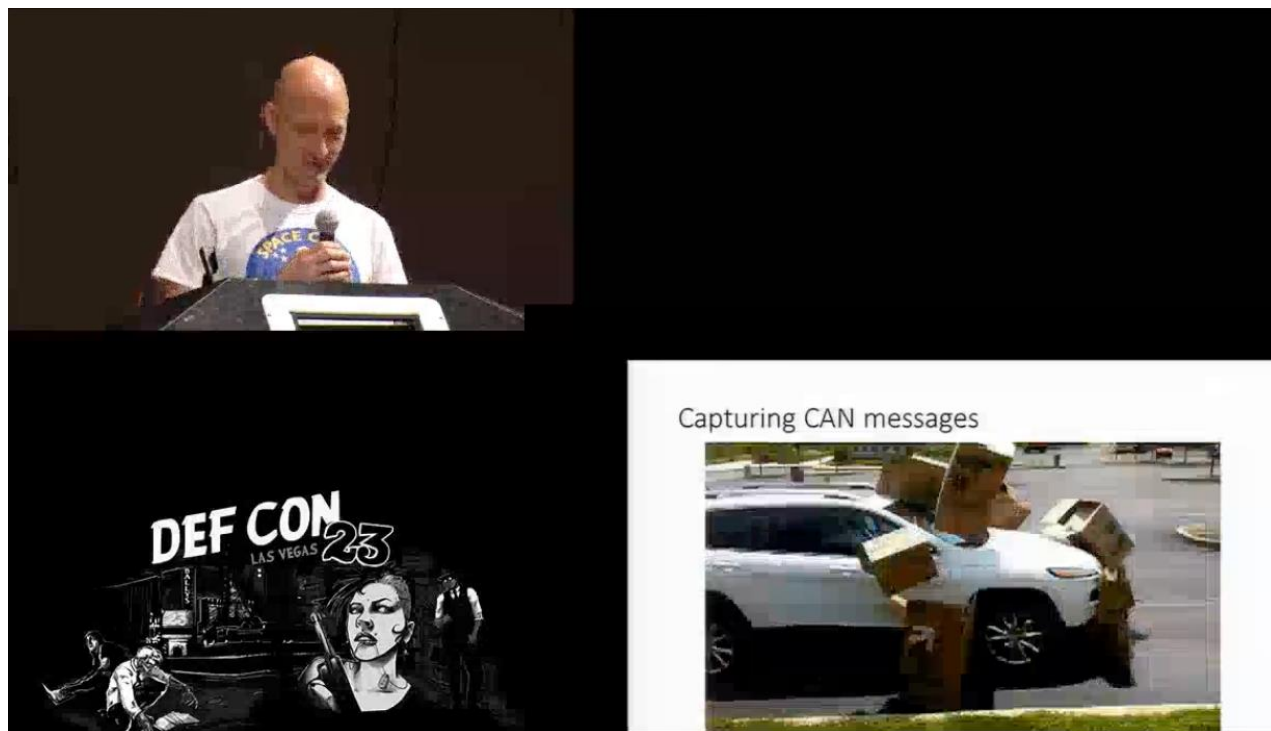
9.3.0.260327

```
101  {
102  {
103      if ( &__cxa_finalize )
104          _cxa_finalize(_dso_handle);
105      result = deregister_tm_clones();
106      _TMC_END__ = 1;
107  }
108  return result;
109  }
110  // 4010: using guessed type char _TMC_END__;
111
112  //----- (0000000000001140) -----
113  __int64 frame_dummy()
114  {
115      return register_tm_clones();
116  }
117  // 1140: using guessed type __int64 frame_dummy();
118
119  //----- (0000000000001149) -----
120  int __fastcall main(int argc, const char **argv, const char **envp)
121  {
122      puts("Hello, World!");
123      return 0;
124  }
125
126  //----- (0000000000001168) -----
127  // Alternative name is '_fini'
128  void term_proc()
129  {
130      ;
131  }
132
133  // nfuncs=18 queued=10 decompiled=10 lumina nreq=0 worse=0 better=0
134  // ALL OK, 10 function(s) have been successfully decompiled
```

<https://dogbolt.org>

技術：程式漏洞挖掘與利用

- > 程式運作原理
- > 作業系統內建保護功能
- > 常見程式漏洞類型
- > 漏洞利用原理
- > 工具
 - > GDB
 - > Fuzzer



Remote Exploitation of an Unaltered Passenger Vehicle

技術：數位鑑識

- > 檔案系統與記憶體鑑識
- > 事件時間軸重建
- > 證據留存
- > 工具
 - > Volatility
 - > FTK
 - > Autopsy

The BIG digital warhead

```
M117: L      LWO
      L      164
      <=I
      SPBN   M101
```

The number 164 pops up quite often
in code & data

```
Array [1..984]: DWORD
Array [1..984]: BOOL
Array [1..6] [1..164]: BYTE
DWORD
```

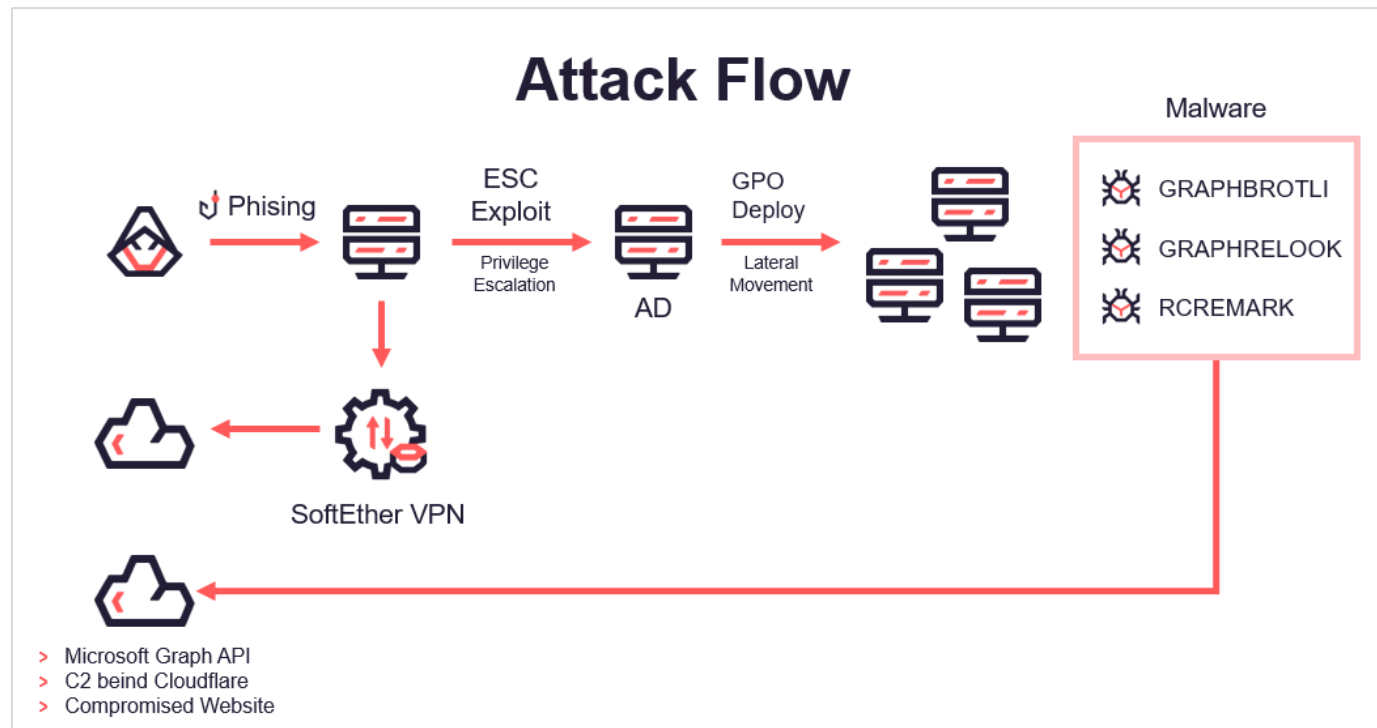
IR-1 centrifuges are grouped in
cascades of 164 units each

of cascades (C1 and C2)
standard 164-machine
type of centrifuge (P-1),
multiple of 164 machines
which represent

Cracking Stuxnet, a 21st-century cyber weapon

技術：事件追蹤與分析

- > 日誌與告警關聯分析
- > 端點與網路行為追蹤
- > 攻擊技術與階段
- > 工具
 - > MITRE ATT&CK
 - > SIEM (Splunk / ELK)
 - > Sigma / YARA



無基礎設施攻擊：利用 Dead-Drop Resolver 與 MS Graph API 洗白 C2 流量

資安工作的一些特性

不同職位的工具和技能
差異甚大。

1. 許多基礎知識與技術是通用的

- > 程式與網頁漏洞的成因 $\longleftrightarrow$ 事件追蹤與分析
- > 惡意程式攻擊手法 $\longleftrightarrow$ 數位鑑識
- > 逆向工程 / 網路 / 密碼學 / 身份認證的基礎知識

2. 資安工作十分注重實作能力

- > 不能只停留在「理解原理」的知識層級
- > 知識原理 $\rightarrow$ 工具操作 $\rightarrow$ 技能演練 $\rightarrow$ 實際運用

藍隊的 (一部分) 知識、工具與技能

實際運用	整理入侵特徵 產業威脅報告	規則上線 誤報調校	告警分流 帳號被盜處理	入侵時間軸 鑑識報告	CVE 通報 議程投稿
技能演練	重建 APT 時間軸 整理公開報告	重放攻擊 驗證規則抓得到	公開 log 資料集 自架 VPS 練習	forensic CTF 公開映像檔練習	pwn / rev CTF 讀開源原始碼
工具操作	VirusTotal Shodan Python	Sigma YARA Git	SIEM 查詢 EDR console regex, SQL	Autopsy Volatility FTK Imager	IDA / Ghidra gdb, pwntools
知識原理	攻擊生命週期 ATT&CK 框架	log 欄位語意 誤報與漏報	作業系統 網路與協定	檔案系統 系統痕跡	計算機組織 記憶體與編譯
	威脅情資	偵測工程	SOC / 工程	數位鑑識	資安研究

Lab : SIEM 初體驗

實際運用	整理入侵特徵 產業威脅報告	規則上線 誤報調校	告警分流 帳號被盜處理	入侵時間軸 鑑識報告	CVE 通報 議程投稿
技能演練	重建 APT 時間軸 整理公開報告	重放攻擊 驗證規則抓得到	公開 log 資料集 自架 VPS 練習	forensic CTF 公開映像檔練習	pwn / rev CTF 讀開源原始碼
工具操作	VirusTotal Shodan Python	Sigma YARA Git	SIEM 查詢 EDR console regex, SQL	Autopsy Volatility FTK Imager	IDA / Ghidra gdb, pwntools
知識原理	攻擊生命週期 ATT&CK 框架	log 欄位語意 誤報與漏報	作業系統 網路與協定	檔案系統 系統痕跡	計算機組織 記憶體與編譯
	威脅情資	偵測工程	SOC / 工程	數位鑑識	資安研究

什麼是 SIEM ？

- > SIEM 就像是企業資安的「中央監控塔台」或「黑盒子」，它將防火牆、伺服器、端點設備、資料庫及雲端平台分散各處的日誌和事件紀錄集中在單一平台，幫助資安團隊即時發現潛在威脅並做出應變。

如何監控電腦的運作？

> 透過系統日誌服務，保留系統上特定事件發生時的相關資訊

> Sysmon

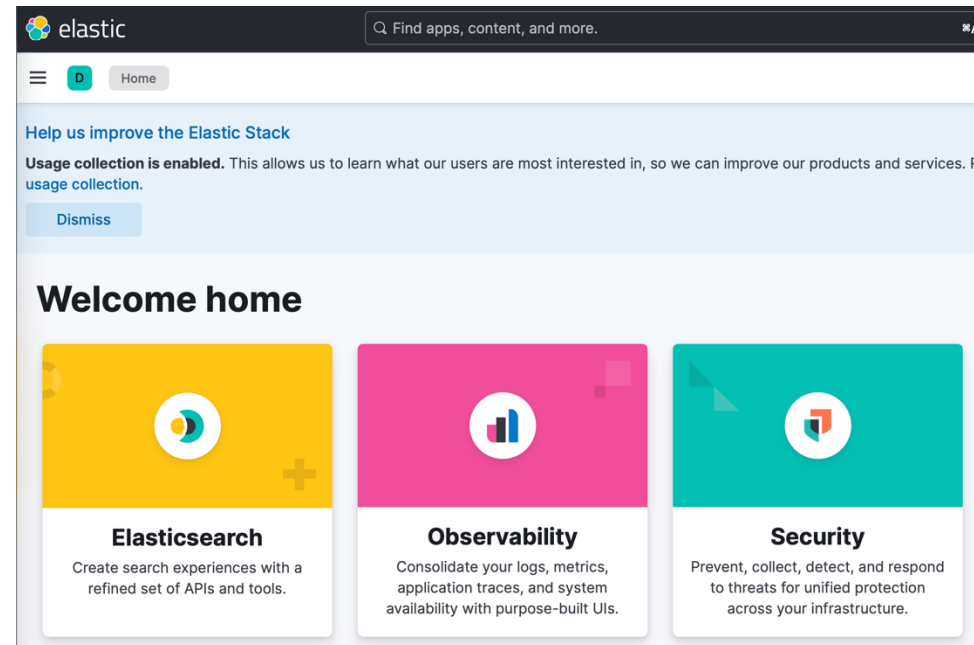
- > Process 建立時的完整 command line, process id, parent process id 等
- > 檔案被建立或複寫
- > ...

> PowerShell

- > PowerShell 執行時的指令內容
- > Applications and Services Logs > Microsoft > Windows > PowerShell > Operational
- > Event ID 4104 – Script Block Logging

Lab Setup

- > Install Docker
- > git clone <https://github.com/Ice1187/siem-lab>
- > Run ./setup.sh
- > Open 127.0.0.1:5601





Demo



登入 pbeesly

Find apps, content, and more.

Security

Explore

Users

pbeesly

Events

Security

Dashboards

Rules

Alerts

Attack discovery

Findings

Cases

Timelines

Intelligence

Explore

Filter your data using KQL syntax

Sep 10, 2026 @ 09:17:00.176

C:\Windows\Temp\python.exe

Sep 10, 2026 @ 09:19:17.894

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \

Sep 10, 2026 @ 09:19:16.879

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \

Sep 10, 2026 @ 09:19:08.399

C:\Windows\System32\RuntimeBroker.exe -Embedding

Sep 10, 2026 @ 09:19:08.312

"C:\windows\system32\backgroundTaskHost.exe" -ServerName:.

Sep 10, 2026 @ 09:19:01.247

C:\windows\System32\rundll32.exe C:\windows\System32\shell32

Sep 10, 2026 @ 09:19:00.226

C:\windows\system32\DllHost.exe /Processid:{4D111E08-CBF7-

Sep 10, 2026 @ 09:18:53.809

taskhostw.exe Install \$(Arg0)

Sep 10, 2026 @ 09:18:50.266

C:\Windows\System32\RuntimeBroker.exe -Embedding

Sep 10, 2026 @ 09:18:49.184

"C:\windows\system32\backgroundTaskHost.exe" -ServerName:.

Sep 10, 2026 @ 09:18:24.973

\\?\C:\windows\system32\conhost.exe 0xffffffff -ForceV1

Sep 10, 2026 @ 09:18:23.804

\\?\C:\windows\system32\conhost.exe 0xffffffff -ForceV1

Sep 10, 2026 @ 09:18:23.801

"C:\Windows\Temp\python.exe"

Sep 10, 2026 @ 09:18:03.659

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \

Sep 10, 2026 @ 09:18:02.639

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \

Sep 10, 2026 @ 09:17:21.444

\\?\C:\windows\system32\conhost.exe 0xffffffff -ForceV1

Sep 10, 2026 @ 09:17:21.379

\\?\C:\windows\system32\conhost.exe 0xffffffff -ForceV1

Sep 10, 2026 @ 09:17:21.376

"C:\Windows\Temp\python.exe"

Sep 10, 2026 @ 09:17:00.176

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \

Sep 10, 2026 @ 09:16:59.152

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \

Rows per page: 100

Expand details

Sep 10, 2026 @ 09:17:00.176

Psexec64.exe

Overview

Table

JSON

@timestamp

Sep 10, 2026 @ 09:17:00.176

@timestamp_original

May 2, 2020 @ 11:12:26.669

@version

1

Category

Process Creation

Channel

Security

CommandLine

"C:\Program Files\SysinternalsSuite\Psexec64.exe" -accepteula \\NASHUA -u dmevals\pbeesly -p FI0nk3rt0n!T0by -i 2 C:\Windows\Temp\python.exe

EventID

4688

EventReceivedTime

2020-05-01 23:12:26

EventTime

2026-09-09 21:16:58

EventTime_original

2020-05-01 23:12:25

AI 已能自主進行事件調查與分析

- 入侵事件時間軸已重建

<https://claude.ai/code/artifact/dc5e5ed6-97ca-4ed0-a95a-daf7000f3f62>

由於此環境未載入 Elasticsearch MCP 工具本身，我改以直接查詢 apt29-mcp-proxy (127.0.0.1:9280，反向代理 apt29-es 容器) 取得的原始資料完成調查，涵蓋 Sysmon process-create、network-connection、registry、file-create 以及 PowerShell 日誌共 196,081 筆事件。

攻擊鏈摘要 (02:00:31 - 02:26:45，共 4 台主機中 2 台淪陷)：

1. 初始入侵：pbeesly 於 SCRANTON 執行以 RTLO 字元偽裝成 .doc 的 cod.3aka3.scr，隨即回連 192.168.0.5:1234
2. 提權與執行：sdclt.exe UAC 繞過 → 隱藏 PowerShell 從 monkey.png 萃取隱寫 payload 並執行
3. 持久化：Startup 捷徑 hostui.lnk + 登錄檔 HKLM\SOFTWARE\Javasoft\value Supplement 存放無檔案 gzip PowerShell stager
4. 憑證存取：PowerShell 兩度以 PROCESS_ALL_ACCESS 存取 lsass.exe
5. 橫向移動：WinRM 偵察後，以 明文密碼 (Fl0nk3rt0n!T0by) 透過 PsExec 將 Python 植入物部署至 NASHUA，持續信標回連 192.168.0.4:8443 (近 350 次連線)
6. 蒐集與清痕：Rar.exe 密碼壓縮 working.zip 準備外洩，隨後以 sdelete64 清除所有工具與壓縮檔
7. 持久化驗證：SCRANTON 重開機後，Startup 鏈確實在 02:26:37 重新觸發並復原 C2 存取

頁面內含完整分階段時間軸、IOC 清單與 MITRE ATT&CK 技術對照表。時間戳記為實驗室相對時間 (壓縮在 32 分鐘內)，主機命名與情境高度吻合公開的 APT29 模擬演練資料集。

* Sautéed for 10m 27s · done 下午5:34

AI 對資安的影響與未來發展 (個人見解)

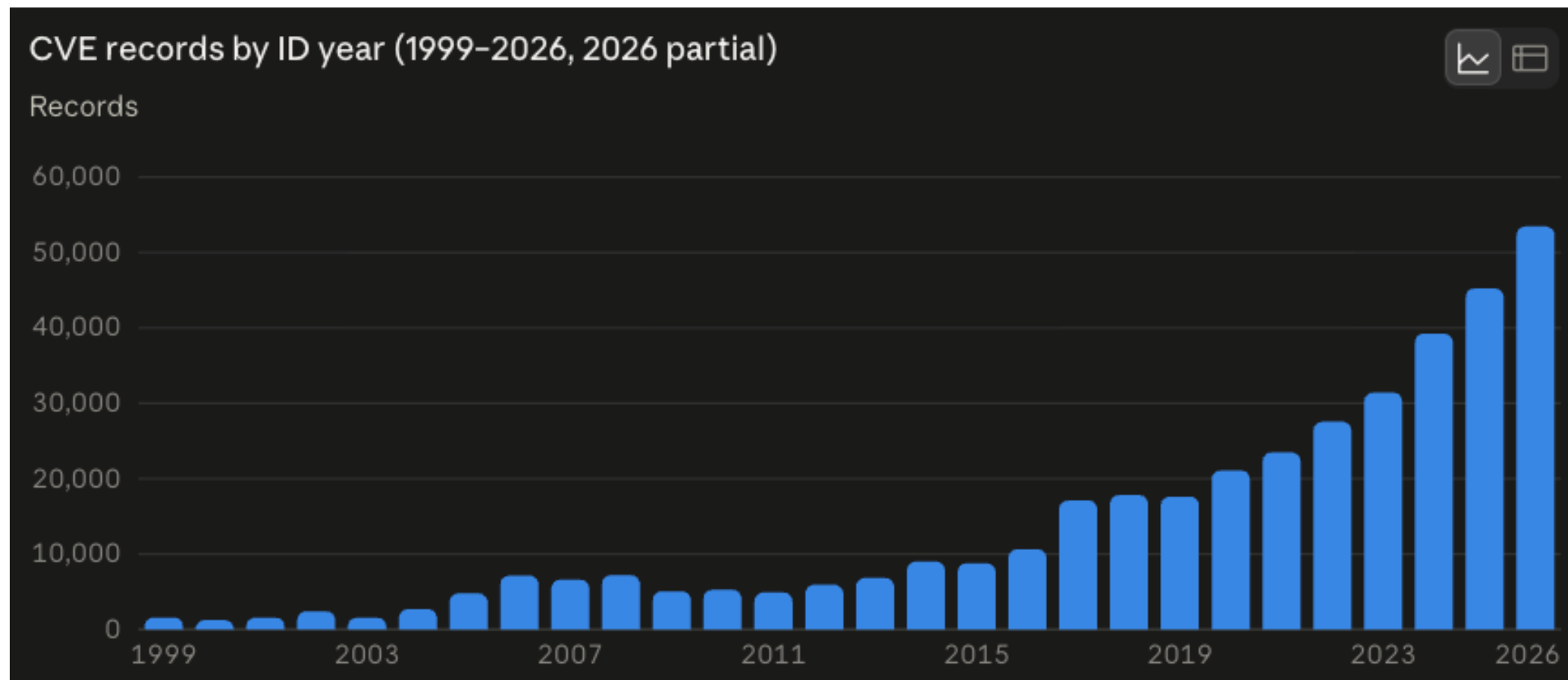


AI 帶來的改變

- > 漏洞挖掘大幅加速
- > 防禦方逐漸自動化
- > 專業技能可被 AI 取代

漏洞挖掘大幅加速

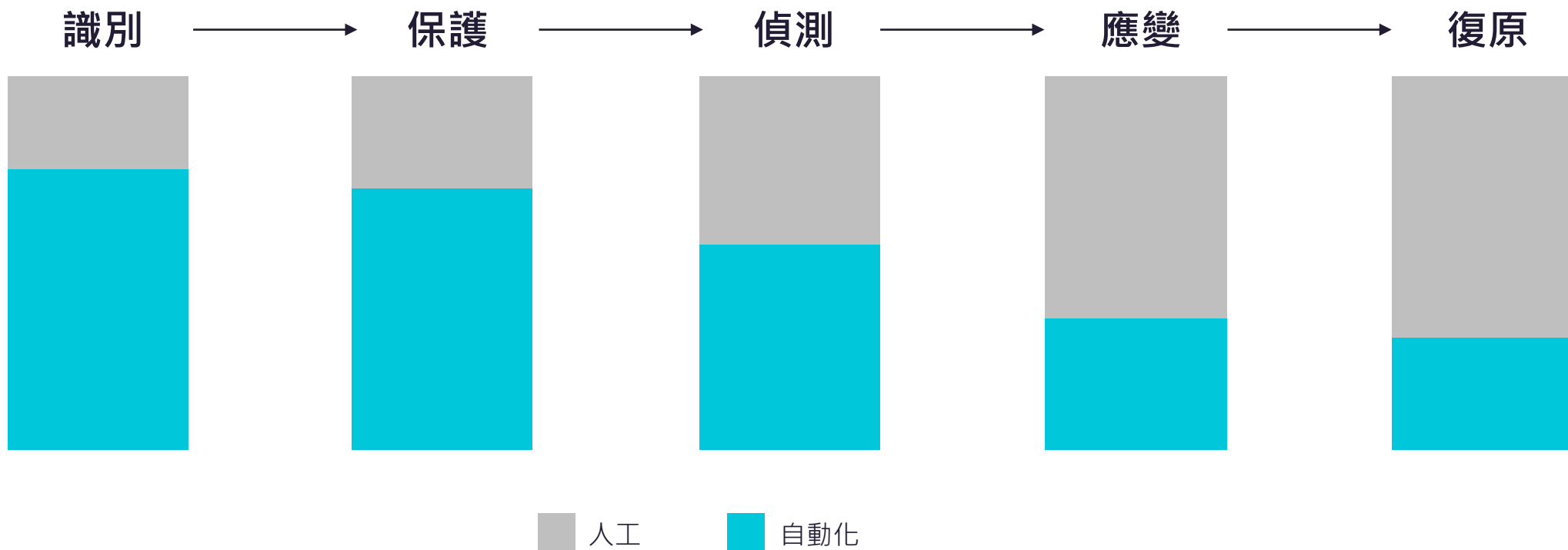
挖洞速度、深度與漏洞總量暴漲



Data collection and chart by Claude (Anthropic)

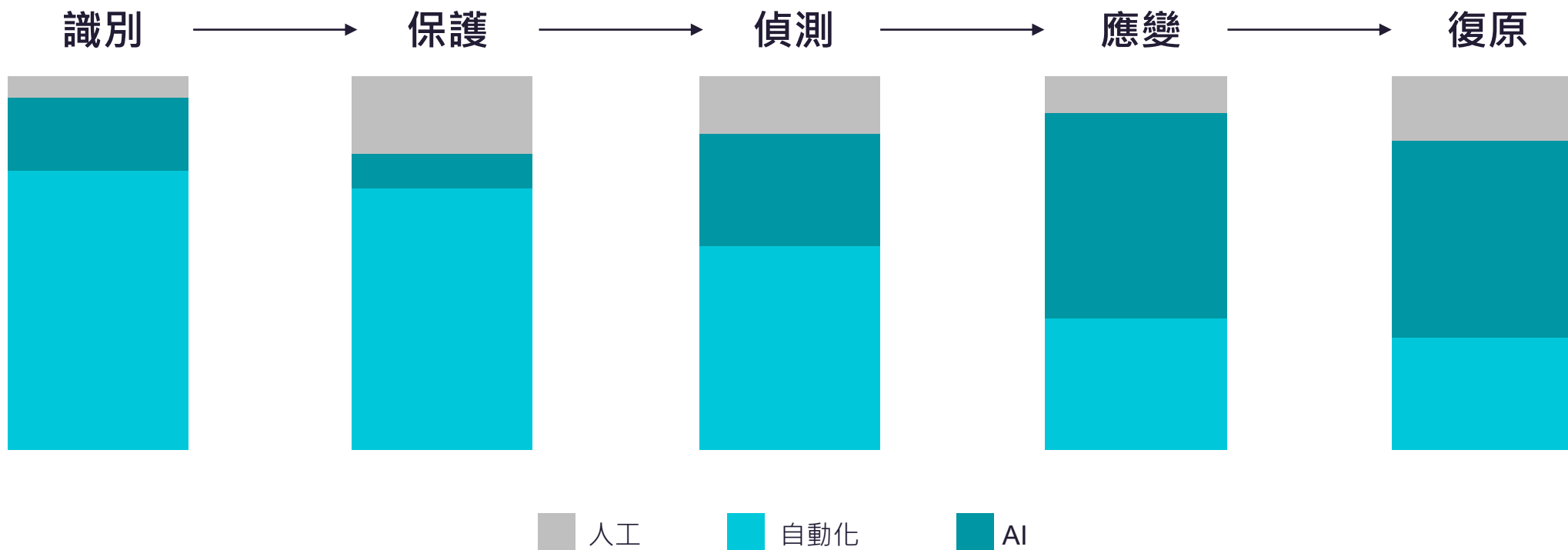
防禦方逐漸自動化

過去難以自動化的事件應變、漏洞修補逐漸被攻克，但速度遠不如攻擊方



防禦方逐漸自動化

過去難以自動化的事件應變、漏洞修補逐漸被攻克，但速度遠不如攻擊方



原有平衡被打破，駭客攻防進入新的動態平衡

- > 攻擊的技術與自動化門檻降低，攻擊將會大量提升
 - > 國家級駭客戰的滲透將會更深更廣
 - > 針對企業的勒索與資料販賣將會更加猖獗
- > 導致政府和具高價值資料企業的資安需求大幅提升
- > 缺乏資源投注於資安防護的中小企業與 NGO 會更容易被入侵
 - > 資安不只是技術問題，也是需付出成本的經濟問題
 - > 當防護成本 > 資產價值，選擇不防才是理性的經濟決策
- > 可能會出現勒索與賣資料以外的變現方式

專業技能可被 AI 取代

當 AI 能夠自行包辦挖洞、入侵、偵測、調查、修補時，我們還能做些什麼？



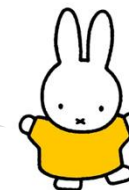
同事 J

年底績效還差一點，來打個 IoT 順便投稿？

公司不是有訂閱 Claude 嗎？



好哇。但上班忙得要死，下班只想躺平。哪有空挖洞？



我

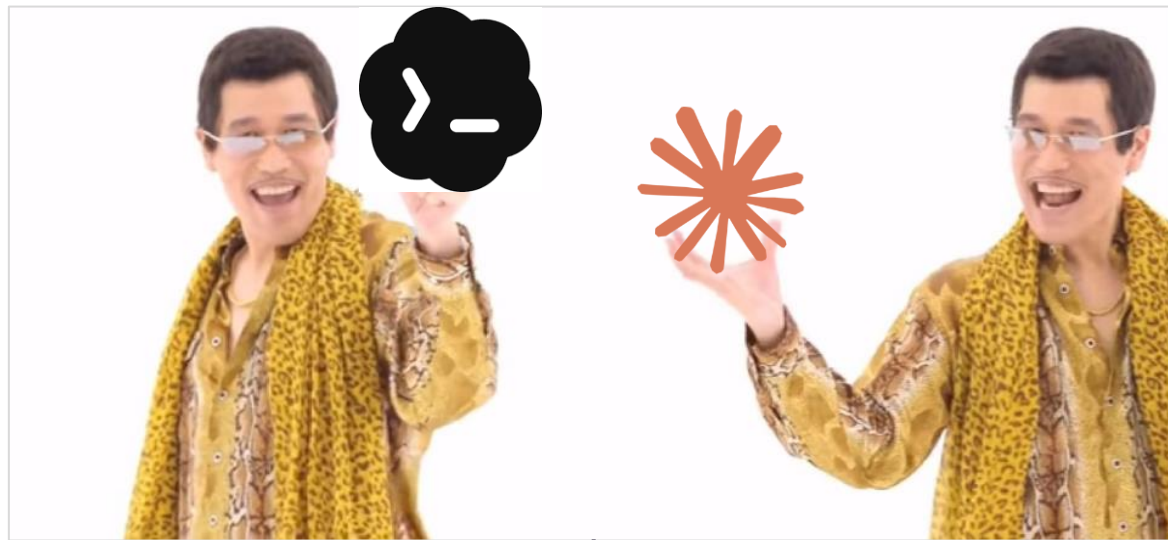
I'll start by extracting the client app and reversing the firmware. Once it's done, ...



Claude

專業技能可被 AI 取代

當 AI 能夠自行包辦挖洞、入侵、偵測、調查、修補時，我們還能做些什麼？



一個禮拜過後



我們生活在「以人為中心」的社會

人依然有很多特質是 AI 無法取代的。

1. AI 無法看見全局

- > 人的關係、互動方式、期待等過於複雜，難以用文字表達
- > 不可能一直即時更新所有你與其他人互動的細節

2. AI 無法主動想做什麼

- > 主動決定要做什麼、要怎麼做是推進事物發展的根本
- > 與 AI 互動的人必須承擔做這些決定的責任

3. AI 無法根除幻覺

- > 信任是安全最重要的一環，也是與人互動很重要的基礎
- > 在（許多）關鍵之處，依舊需要人來驗證或承擔後果

AI 時代的資安環境需要什麼樣的人才？

AI 能夠強化人的生產力，
但無法取代人類。

1. AI 應用能力會是新的基礎技能

- > 將需求表達成文字的能力；將 AI 產出傳達給他人的能力
- > 當所有人都用 AI 後，會用 AI 就不再是一種優勢

2. 技術實力依然是核心硬需求

- > 技術工作將會 90% 以指揮 AI 為主，10% 人工輔助與驗證產出
- > 培養技術實力時，也養成 AI 無法取代的判斷能力與溝通基礎

3. 專案管理的重要性提升

- > AI 讓我們從技術細節中解放，並且 10 倍加速開發速度
- > 加速十倍的同時，也讓選對方向更重要（選錯浪費 10 倍）

建議

- > 如果擔心 AI 會取代你的工作，可以嘗試實際動手去做出能取代你的 AI。

如何入門資安？

- > 台灣資安 / CTF 學習資源整理
- > PortSwigger Web Security Academy
- > HackTheBox Academy
 - > Skill Paths
 - > Job Role Paths
 - > Certifications



資安學習資源

如果對入門資安有興趣：

1. 歡迎課後來找我討論
2. 到老師們的資安 lab 做專題

加入資安 CYBER AI

奧義智慧科技榮獲多項最佳雇主大獎



HR Asia
BEST COMPANIES
TO WORK FOR
IN ASIA 2023

We Are Hiring

- > 資安鑑識工程師
- > 資安威脅研究員
- > ML 資料科學工程師
- > 軟體開發工程師
- > SRE/DevOps 工程師
- > 資安研發替代役
- > 奧義學院 – 實習計畫



CYCRAFT
奧義智慧科技

實習招募連結



歡迎寄信找我聊聊 / 修履歷

icing1187@gmail.com

CYCRAFT



回饋表單

Q&A

Thanks for your participation.



Slido 提問

